

12-Phishing - Phishmas Greetings

Introduction

The Story

Desde la desaparición de McSkidy, las defensas de TBFC se han debilitado y la Plataforma de Protección de Correo Electrónico (SOC) ha caído.

Con los filtros desconectados, el personal debe clasificar manualmente cada mensaje sospechoso.

El equipo SOC sospecha que los Eggsplot Bunnies de Malhare han enviado mensajes de phishing a los usuarios de TBFC para robar credenciales e interrumpir las SOC-mas.



Te has unido al Grupo de Trabajo de Respuesta a Incidentes para ayudar a identificar qué correos electrónicos son legítimos o intentos de phishing.

Pero ten cuidado, algunos intentos de phishing son astutos y se disfrazan de operaciones rutinarias de TBFC, inscripciones de voluntarios o logística del evento SOC-mas. Cada llamada equivocada podría acercar a Wareville un paso más a la realización de EAST-mas.

Objetivos de aprendizaje

- Detección de correos electrónicos de phishing
- Aprender las técnicas de phishing más populares
- Comprender las diferencias entre spam y phishing

Inicie el equipo de destino haciendo clic en el botón "Iniciar equipo" que aparece a continuación. El equipo tardará entre 2 y 3 minutos en iniciarse por completo. A continuación, puede acceder al Inspector de amenazas de correo electrónico de Wareville en https://LAB_WEB_URL.p.thmlabs.com.

Nota: Si recibe un error 502 al acceder al enlace, espere un poco más para que el equipo se inicie por completo.

Answer the questions below

I have access to the Wareville Email Threat Inspector!

No answer needed

Spotting Phishing Emails

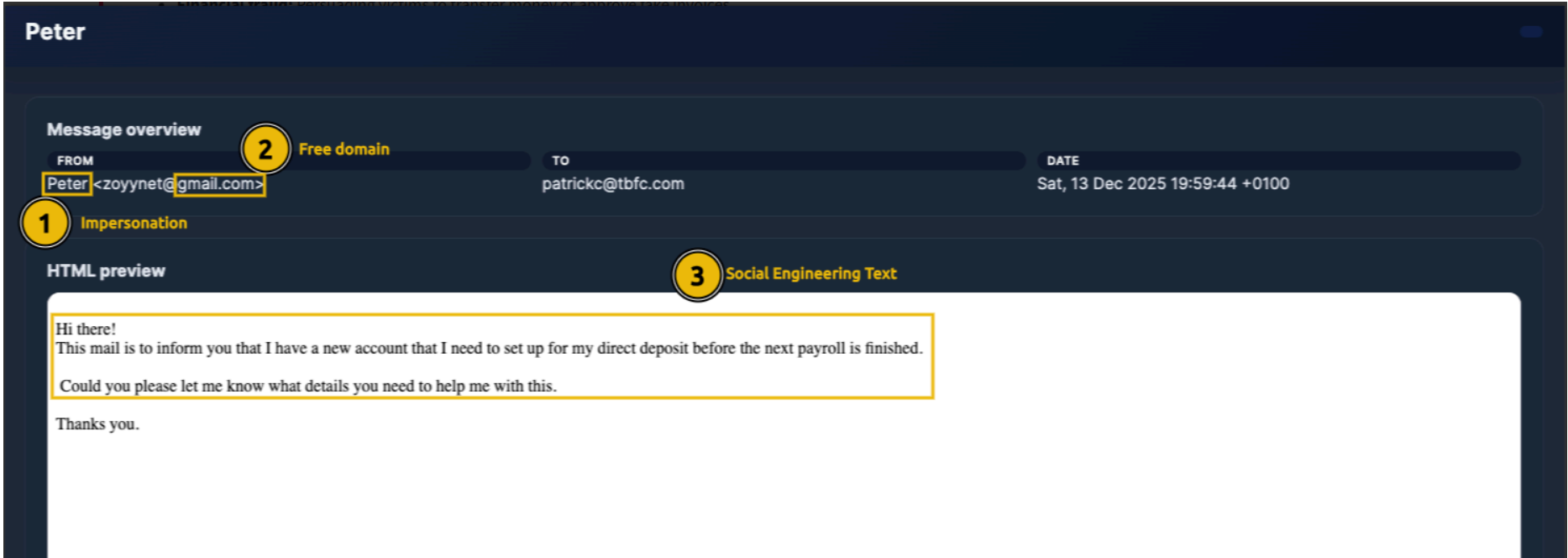
Resumen del phishing

El phishing puede ser uno de los trucos cibernéticos más antiguos, pero sigue siendo uno de los más efectivos. A medida que empresas como TBFC refuerzan sus defensas con filtros de correo electrónico avanzados y herramientas de seguridad, los atacantes han evolucionado sus tácticas para ir un paso por delante.

El phishing moderno se centra en la precisión y la persuasión. Los mensajes se elaboran cuidadosamente, a menudo imitando a personas reales, portales o procesos internos para engañar incluso a los usuarios más precavidos.

Intenciones comunes de los mensajes de phishing:

- **Robo de credenciales:** Engañar a los usuarios para que revelen contraseñas o datos de inicio de sesión.
- **Distribución de malware:** Disfrazar archivos adjuntos o enlaces maliciosos como contenido seguro.
- **Exfiltración de datos:** Recopilación de información confidencial de la empresa o personal.
- **Fraude financiero:** Persuadir a las víctimas para que transfieran dinero o aprueben facturas falsas.



En la imagen de arriba, podemos ver un ejemplo de mensaje de phishing de un atacante que intenta hacerse pasar por un empleado utilizando un dominio gratuito (gmail.com) para modificar su nómina y cometer fraude financiero.

Con los perímetros corporativos fuertemente fortificados, el phishing sigue siendo la vía más fácil para el acceso inicial. Se dirige a la única vulnerabilidad que la tecnología no puede solucionar: las personas. Incluso en Wareville, un solo correo electrónico convincente de las Eggsplot Bunnies podría abrir las puertas a EAST-mas.

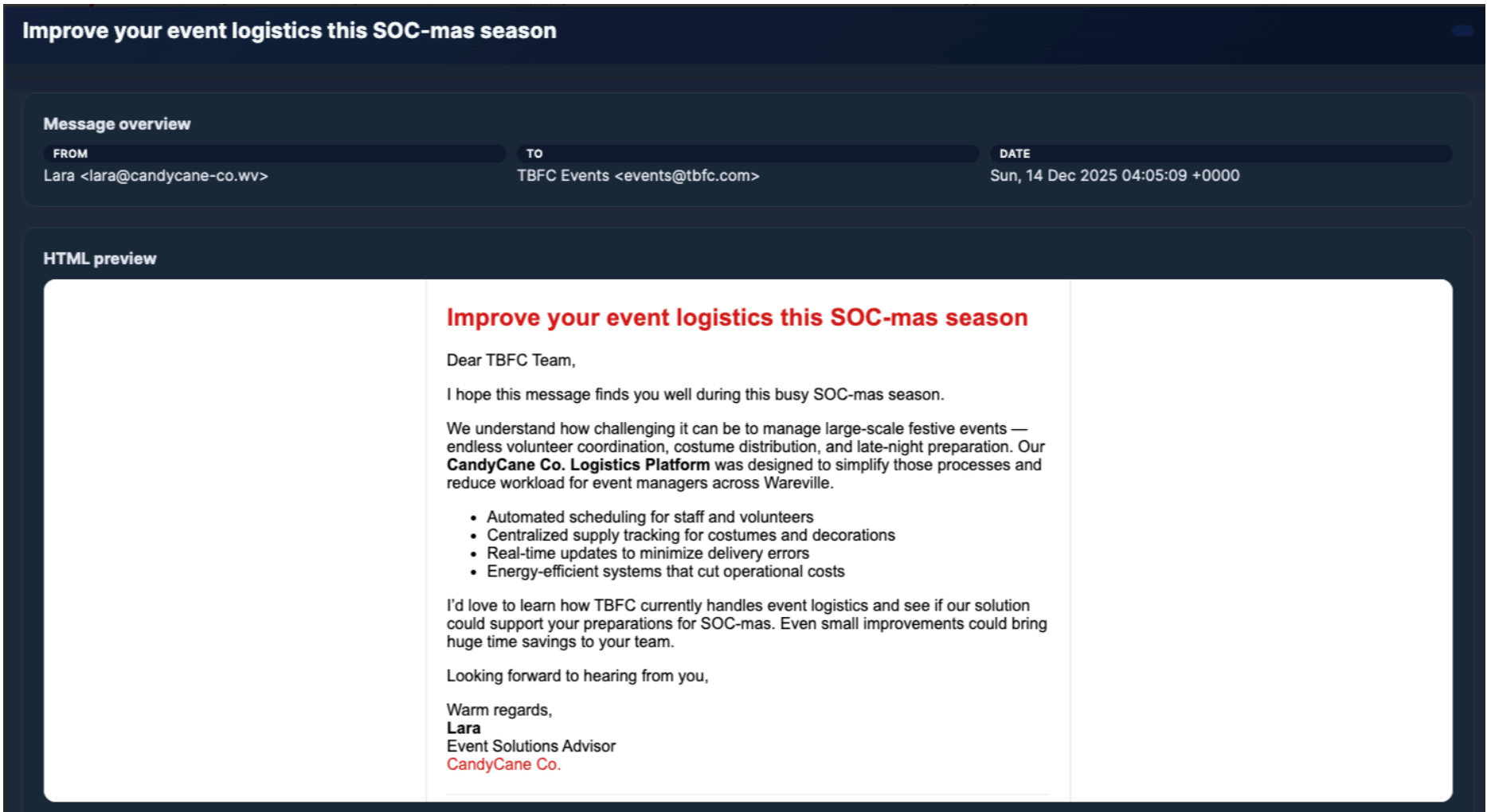
¿Por qué el spam no es phishing?

El spam es simplemente ruido digital: molesto, pero en su mayoría inofensivo. El phishing, sin embargo, es un ataque de precisión, en este caso de las Eggsplot Bunnies de Malhare, diseñado para engañar a los empleados de TBFC y abrir una vía de escape a las defensas de la empresa.

El spam prioriza la cantidad sobre la precisión. A diferencia del phishing, cuyo objetivo es engañar a usuarios específicos, los mensajes de spam se envían masivamente para inundar las bandejas de entrada con marketing no deseado o contenido irrelevante. Su objetivo no suele ser robar datos, sino aumentar la visibilidad o la interacción.

Intenciones comunes tras los mensajes de spam:

- **Promoción:** Publicidad de productos, servicios o eventos. A menudo, no solicitados o de baja calidad.
- **Estafas:** Difundir ofertas falsas o estrategias de "enriquecimiento rápido" para atraer clics.
- **Generación de tráfico (clickbait):** Dirigir a los usuarios a sitios externos o mejorar las métricas publicitarias.
- **Recopilación de datos:** Recopilar direcciones de correo electrónico activas para futuras campañas.



En la captura de pantalla anterior, se muestra un ejemplo de correo electrónico de marketing que ofrece soluciones logísticas para el evento SOC-mas. Se observa que la intención detrás del mensaje es puramente comercial.

Debe analizar cada mensaje con cuidado. Busque la intención subyacente. No todos los correos electrónicos no deseados son una amenaza; a veces son simplemente spam que no representan un riesgo real para TBFC.

El ataque de Phishmas

Los atacantes utilizan técnicas comunes en casi todos los intentos de phishing. En un ataque de phishing, se utiliza al menos una de las siguientes técnicas:

Impersonation

Algunos atacantes pueden hacerse pasar por una persona, un departamento o incluso un servicio para atraer a los usuarios. Esta es una forma de ganar credibilidad haciéndose pasar por el gerente del destinatario o una persona importante de la empresa.

Abra el correo electrónico con el asunto "**URGENT: McSkidy VPN access for incident response**" y revise el campo "From:" del mensaje.

URGENT: McSkidy VPN access for incident response

Message overview

FROM

McSkidy <mcskiddy202512@gmail.com>

TO

TBFC Blue Team <blueteam@tbfc.com>

DATE

Sun, 14 Dec 2025 04:05:09 +0000

Impersonation and free domain usage

HTML preview

Team,

McSkidy here

— I'm currently unreachable by phone. We have an ongoing incident and need the Blue Team to get remote access now to investigate. Please create a new VPN access for me immediately. Send the access to my personal email address mcskiddy202512@gmail.com

Name	McSkidy
Team	Blue Team
Reason	Emergency incident response

This is urgent — please action immediately.

— McSkidy

Podemos detectar fácilmente los intentos de suplantación de identidad al comprobar si el correo electrónico del remitente coincide con el dominio interno o la estructura estándar de la empresa. En este caso, el dominio del remitente es un dominio gratuito de Gmail, que no está alineado con el dominio de TBFC.

Ingeniería social

La ingeniería social en el phishing consiste en manipular a las personas en lugar de descifrar tecnología. Los atacantes crean historias, correos electrónicos, llamadas o mensajes de chat creíbles que explotan las emociones (miedo, ayuda, curiosidad, urgencia) y el contexto real para atraer a los destinatarios.

Ahora, lee el contenido del correo electrónico anterior que abriste. Podemos detectar múltiples técnicas de ingeniería social:

- Suplantación de identidad:** Es un tipo de ingeniería social. ¡El atacante se hace pasar por McSkidy!
- Sentido de urgencia:** Podemos observar palabras como "urgente" e "inmediatamente" para presionar al destinatario.
- Canal lateral:** El atacante intenta disuadir a los destinatarios de contactar con McSkidy utilizando sus canales de comunicación habituales (teléfono y correo electrónico).
- Intención maliciosa:** El atacante intenta engañar al usuario para que proporcione sus credenciales de VPN. También puede intentar solicitar la aprobación de pagos, abrir malware o compartir datos confidenciales.

URGENT: McSkidy VPN access for incident response

Message overview

FROM

McSkidy <mcskiddy202512@gmail.com>

TO

TBFC Blue Team <blueteam@tbfc.com>

DATE

Sun, 14 Dec 2025 04:05:09 +0000

HTML preview

Team,

Discourage to reach out to McSkiddy

Impersonation

McSkidy here

— I'm currently unreachable by phone. We have an ongoing incident and need the Blue Team to get remote access now to investigate. Please create a new VPN access for me immediately. Send the access to my personal email address mcskiddy202512@gmail.com

Sense of Urgency

Name	McSkidy
Team	Blue Team
Reason	Emergency incident response

This is urgent — please action immediately.

Sense of Urgency

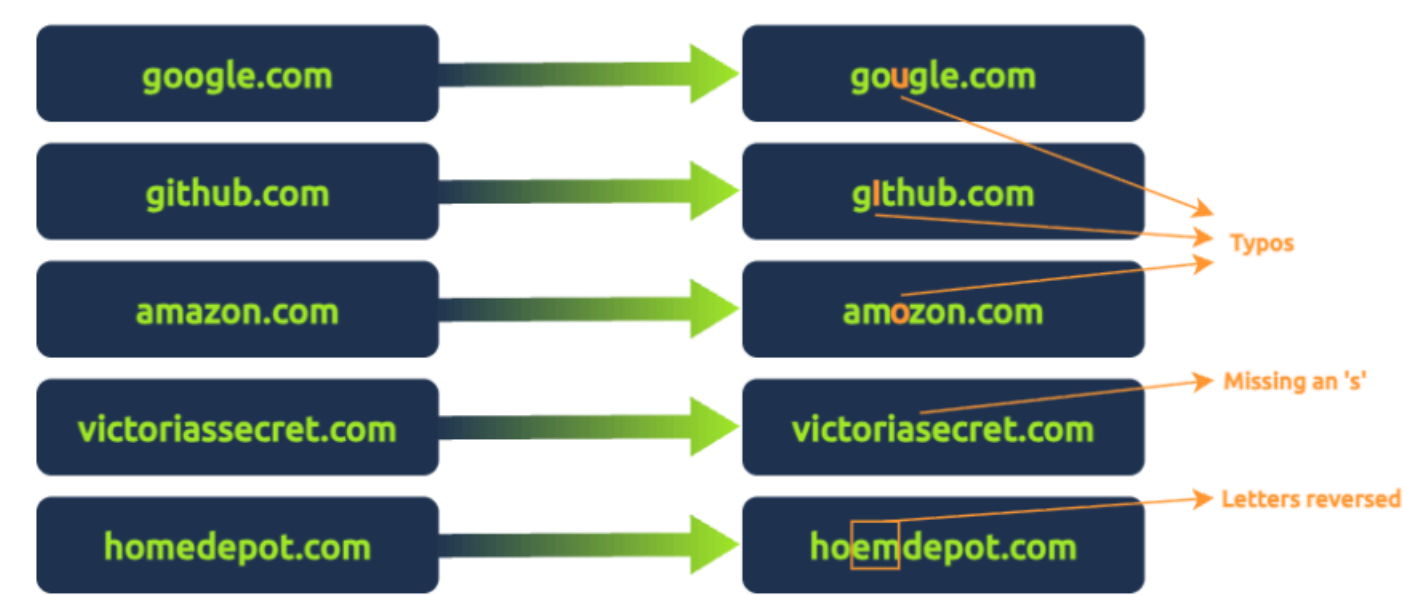
— McSkidy

Typosquatting y Punycode

Has aprendido que revisar el dominio del remitente es una buena manera de detectar intentos de suplantación de identidad de remitentes externos. Pero ¿qué pasa si el atacante crea un dominio muy similar?
En ese caso, el typosquatting y el punycode permiten a los atacantes aprovecharse de la falta de atención (o de conocimiento) de los usuarios.

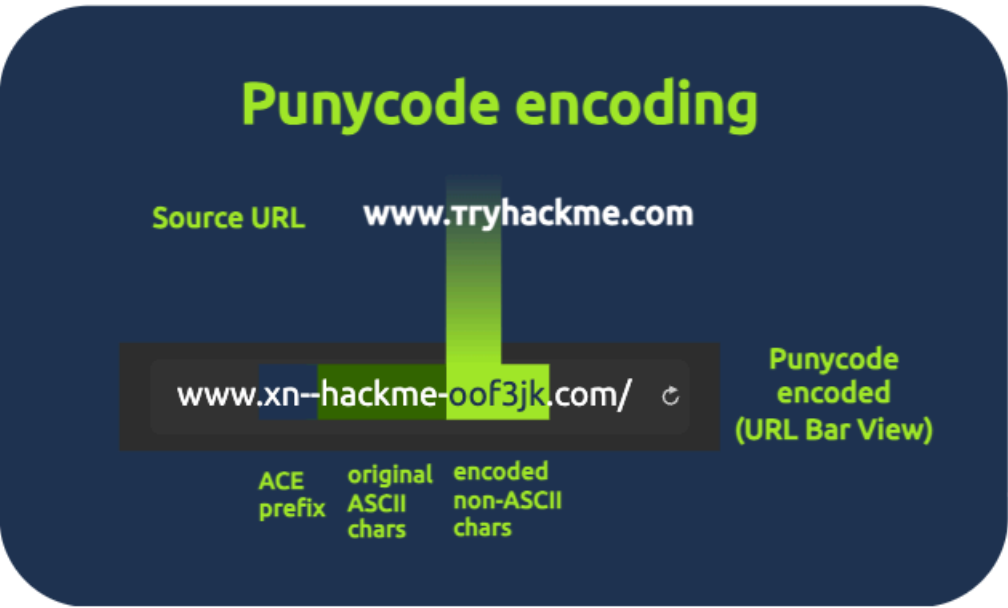
El typosquatting se produce cuando un atacante registra un error ortográfico común en el dominio de una organización. Por ejemplo, "glthub.com" en lugar de "github.com" (observa que hay una L en lugar de una i).

Typosquatting



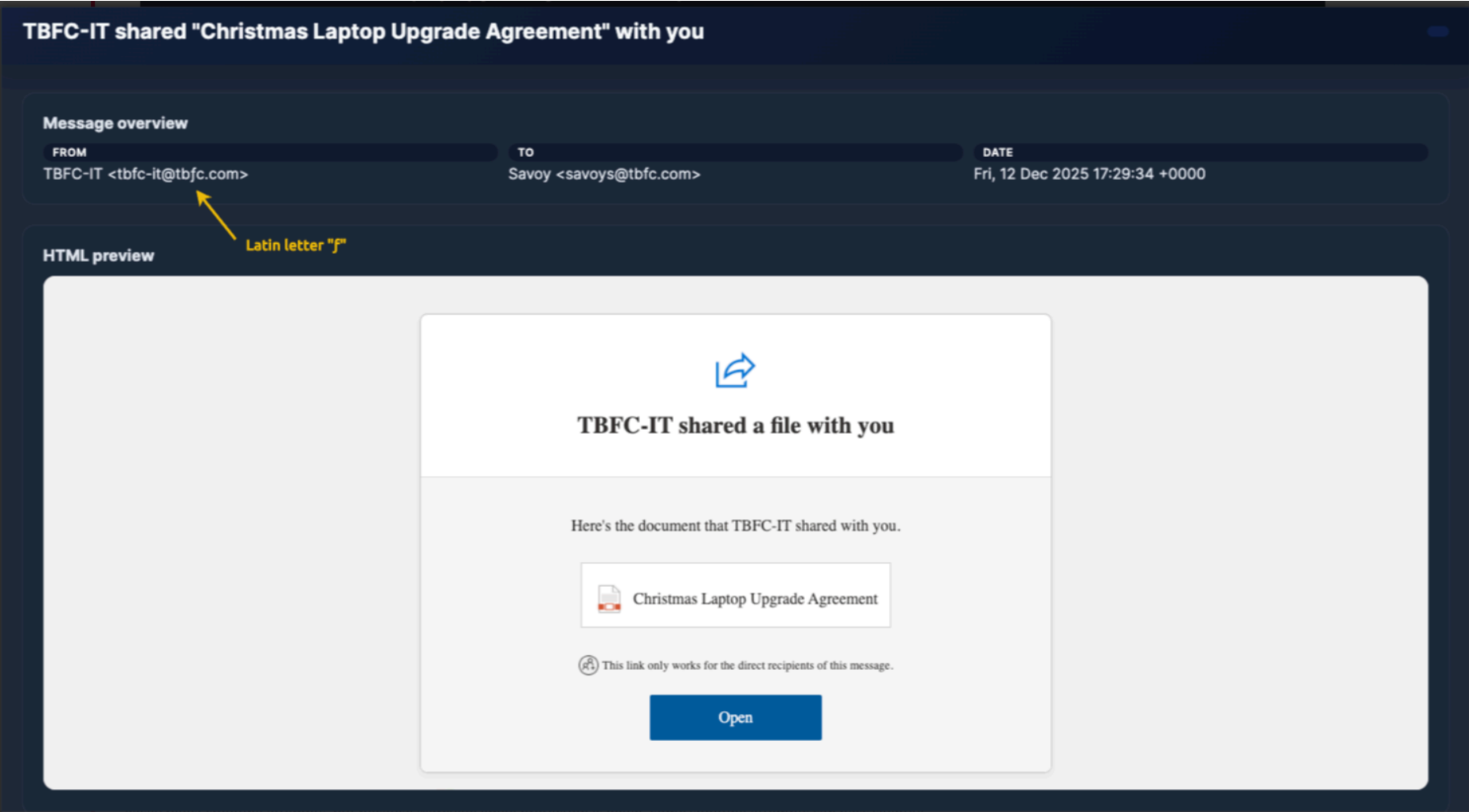
Por otro lado, punycode es un sistema de codificación especial que convierte caracteres Unicode (usados en sistemas de escritura como el chino, el cirílico y el árabe) en ASCII. Al escribir punycodes en la barra de direcciones del navegador, estos se traducirán al formato ASCII, el formato aceptado por DNS. Con este recurso, los atacantes pueden reemplazar letras latinas idénticas; por ejemplo, una "a" latina estándar podría reemplazarse por una "α" griega.

A continuación, se muestra una imagen del dominio tryhackme.com escrito con "try" (t cirílica, r cirílica, y cirílica):



Ambas técnicas permiten a los atacantes registrar dominios maliciosos y engañar a los usuarios haciéndoles creer que reciben correos electrónicos del dominio legítimo o que acceden a sitios web auténticos.

Ahora, abramos el correo electrónico con el asunto **"TBFC-IT shared "Christmas Laptop Upgrade Agreement" with you"**. Si prestamos atención al remitente de este mensaje, podemos identificar una letra latina *f* en lugar de la f normal. Es un claro uso de punycode para un dominio de correo electrónico.



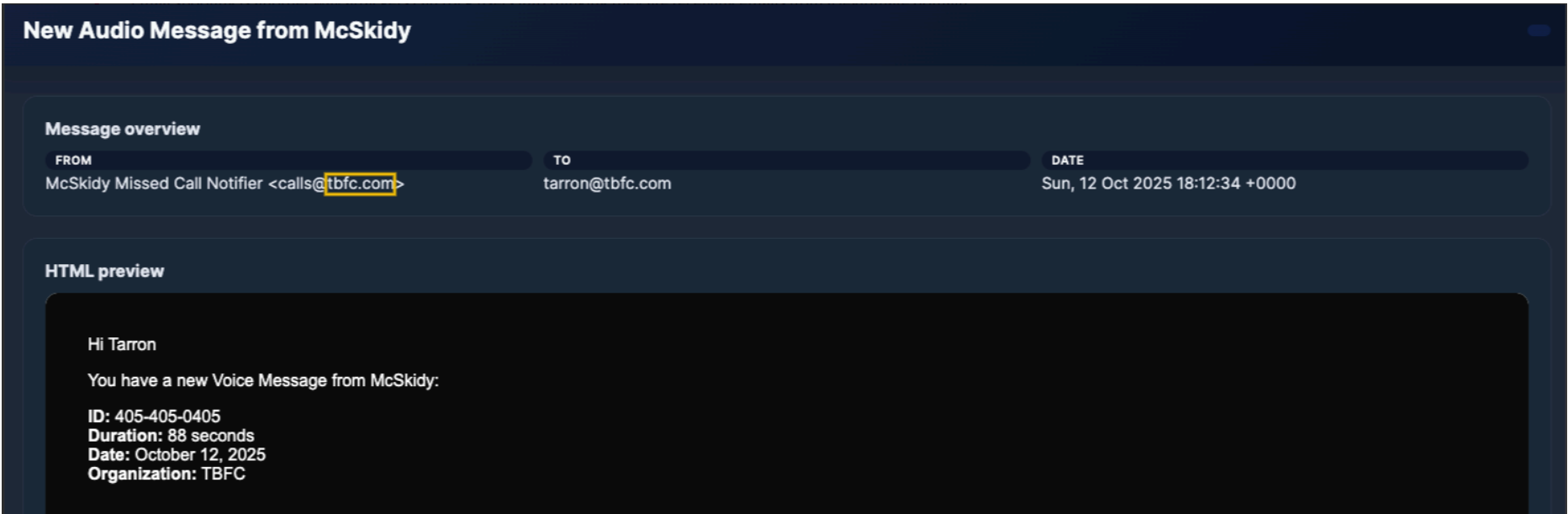
Una forma sencilla de identificar punycodes es consultar el campo "Return-Path" en los encabezados del correo electrónico. En el correo electrónico abierto, vaya a la vista previa de los encabezados y verá el prefijo ACE y los caracteres no ASCII codificados.

Spoofing

La suplantación de identidad de correo electrónico es otra forma en que los atacantes pueden engañar a los usuarios haciéndoles creer que reciben correos de un dominio legítimo.

El mensaje parece provenir de un remitente confiable (el nombre para mostrar y el campo "From:" se ven en la vista previa), pero los encabezados subyacentes cuentan una historia diferente. Los clientes de correo electrónico modernos pueden rechazar fácilmente los intentos de suplantación de identidad, pero debido a que la protección de correo electrónico de Wareville no funciona, algunos intentos de suplantación de identidad pueden pasar desapercibidos.

Abra el correo electrónico con el asunto "**New Audio Message from McSkidy**" y revise el campo "From:".



Parece un dominio real de TBFC, pero revisemos algunos campos esenciales en los encabezados de correo electrónico:

- Authentication-Results
- Return-Path

Headers	
RECEIVED	from DU2PR08MB10188.eurprd08.prod.outlook.com (2603:10a6:10:46f::12) by AM9PR08MB6004.eurprd08.prod.outlook.com with HTTPS; Fri, 12 Dec 2025 11:55:03 +0000
RECEIVED	from AS9PR04CA0039.eurprd04.prod.outlook.com (2603:10a6:20b:46a::33) by DU2PR08MB10188.eurprd08.prod.outlook.com (2603:10a6:10:46f::12) with Microsoft SMTP Server (versi cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7897.13; Fri, 12 Dec 2025 11:53:15 +0000
RECEIVED	from AMS0EPF0000014F.eurprd05.prod.outlook.com (2603:10a6:20b:46a:cafe::22) by AS9PR04CA0039.outlook.office365.com (2603:10a6:20b:46a::33) with Microsoft SMTP Server (v cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7875.21 via Frontend Transport; Fri, 12 Dec 2025 11:53:12 +0000
AUTHENTICATION-RESULTS	spf=fail sender IP is 173.243.133.97) smtp.mailfrom=tbfc.com; dkim=fail signature did not verify) header.d=tbfc.com; dmarc=fail action=none header.from=tbfc.com;compauth=none re:
RETURN-PATH	zxwsedr@easterbb.com
RECEIVED	from gw3097.weakmail.com (173.243.133.97) by AMS0EPF0000014F.mail.protection.outlook.com (10.167.16.251) with Microsoft SMTP Server (version=TLS1_3, cipher=TLS_AES_256_GCM Frontend Transport; Fri, 12 Dec 2025 11:53:12 +0000
AUTHENTICATION-RESULTS-ORIGINAL	gw3097.weakmail.com; spf=permerror (weakmail.com: 143.55.232.2 is neither permitted nor denied by domain of bounce+35b744.72834a-calls.com@tbfc.com) smtp.mailfrom=bounce-calls.com@tbfc.com; dkim=pass header.i=@tbfc.com;

En "Authentication-Results", SPF, DKIM y DMARC son comprobaciones de seguridad que ayudan a confirmar si un correo electrónico proviene realmente de quien dice ser:

- **SPF:** Indica qué servidores tienen permiso para enviar correos electrónicos para un dominio (como una lista de remitentes aprobados).
- **DKIM:** Añade una firma digital para demostrar que el mensaje no se modificó y que realmente proviene de ese dominio.
- **DMARC:** Utiliza SPF y DKIM para decidir qué hacer si un correo electrónico parece falso (por ejemplo, enviarlo a la carpeta de spam o bloquearlo).

Si tanto SPF como DMARC fallan, es una clara señal de que el correo electrónico es falso, lo que significa que el remitente no es quien dice ser. En este caso, ¡todo falló!

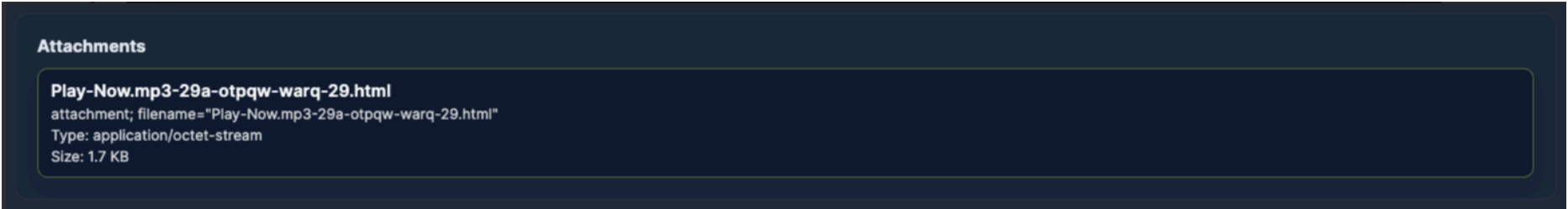
En la Return-Path podemos ver la dirección de correo electrónico real zxwsedr@easterbb.com. Esto confirma el intento de suplantación de identidad en el correo electrónico de llamadas perdidas de TBFC.

Archivos adjuntos maliciosos

La forma más clásica de phishing es adjuntar archivos maliciosos a un correo electrónico. Normalmente, estos archivos adjuntos se envían mediante algún tipo de técnica de ingeniería social en el cuerpo del correo.

En el correo electrónico anterior que analizamos, el cuerpo del correo intentaba engañar a los usuarios haciéndoles creer que el archivo adjunto era un mensaje de voz de McSkidy.

En realidad, el archivo es un archivo ".html"



Los archivos adjuntos maliciosos pueden tener múltiples objetivos. Una vez abiertos, estos archivos pueden instalar malware, robar contraseñas o dar a los atacantes acceso al dispositivo o la red. En este caso, los archivos HTA/HTML se utilizan comúnmente para el phishing porque se ejecutan sin sandbox del navegador, lo que significa que los scripts tienen acceso completo al endpoint en el que se ejecutan.

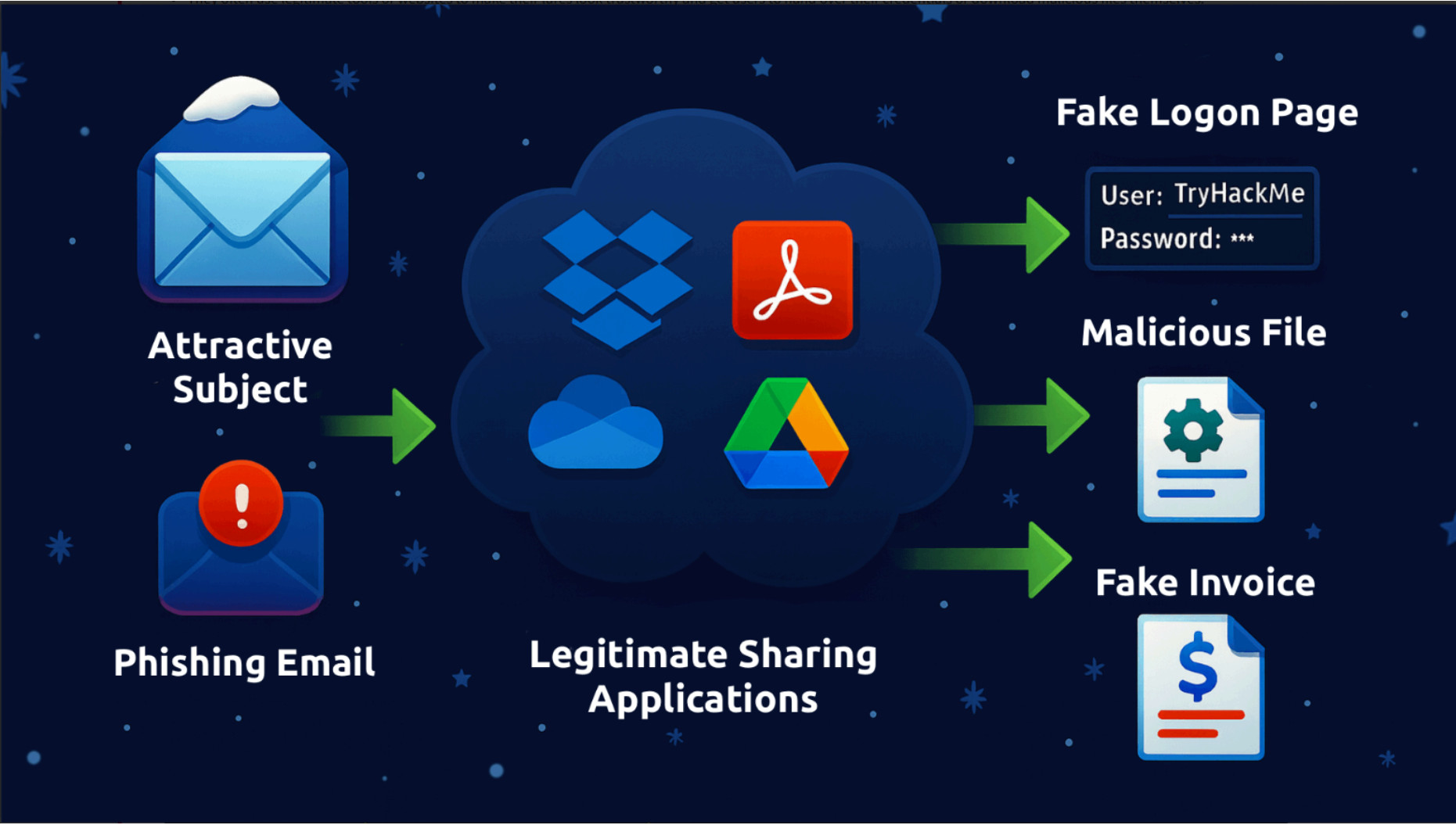
Phishing en tendencia

Dado que las plataformas de correo electrónico y las herramientas de seguridad han mejorado considerablemente el bloqueo de mensajes y archivos adjuntos sospechosos, los Eggsplot Bunnies de Malhare y otros atacantes tuvieron que cambiar su estrategia:

- En lugar de enviar archivos de malware (que son fáciles de detectar), ahora se centran en engañar a los usuarios para que abandonen el entorno seguro de la empresa.

- A menudo utilizan herramientas o sitios web legítimos para que sus señuelos parezcan fiables y que los usuarios proporcionen sus credenciales o descarguen archivos maliciosos.

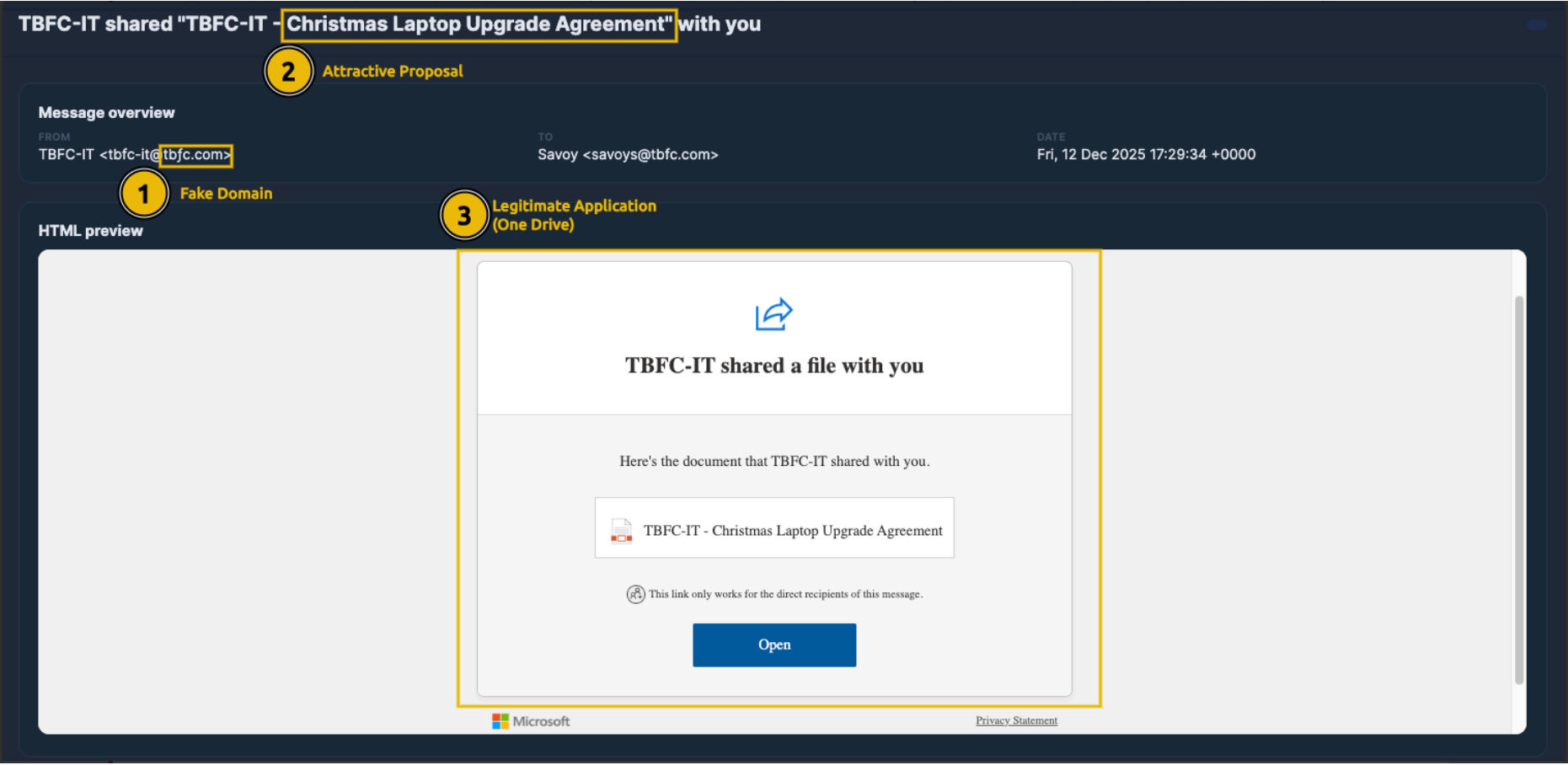
En resumen, la mayoría de los ataques de phishing no se centran en la instalación directa de malware, sino en el robo de acceso. A continuación, puede ver un diagrama de este flujo de tendencias:



Aplicaciones legítimas

Podemos observar que los atacantes se esconden tras servicios de confianza como Dropbox, Google Drive/Docs y OneDrive, ya que esos enlaces parecen legítimos y suelen superar los filtros de correo electrónico. El escenario más común implica un archivo compartido que contiene una propuesta muy atractiva, como un documento de aumento de sueldo de RR. HH. o una actualización de portátil. Al hacer clic en él, el usuario redirige a un documento compartido con contenido falso. El objetivo es atraer a los usuarios a páginas de inicio de sesión falsas para robar credenciales o descargar archivos maliciosos.

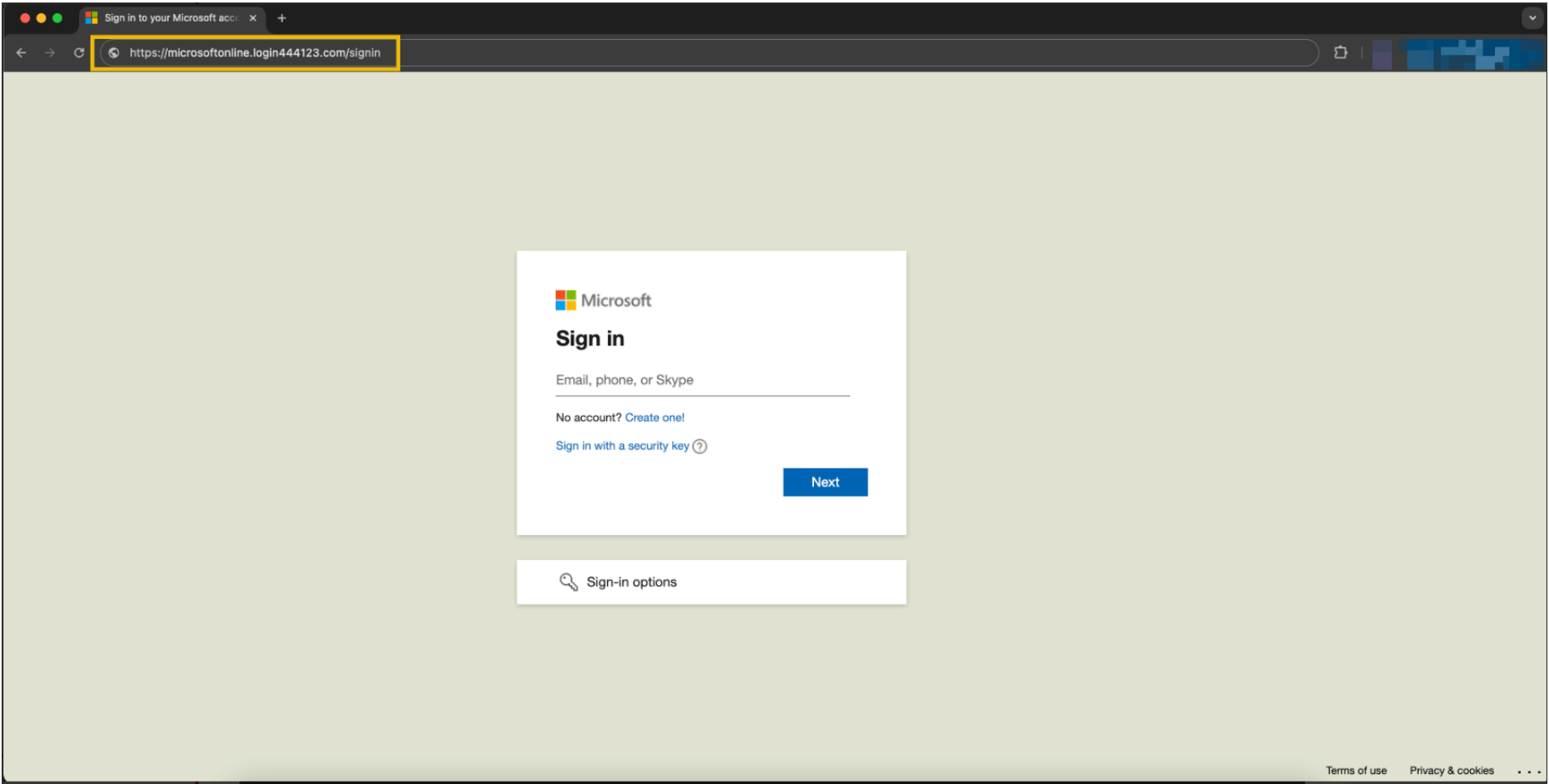
Reabramos el correo electrónico con el asunto "TBFC-IT shared "Christmas Laptop Upgrade Agreement" with you" y analicemos cómo lo utilizan los atacantes:



En la imagen superior, podemos observar el uso de un dominio falso con punycodes para engañar a los usuarios, así como el uso de una herramienta legítima (OneDrive), seguido de una propuesta muy atractiva. Todas estas señales tienen como objetivo principal ganar credibilidad y hacer creer a los usuarios que provienen del equipo de TI real de TBFC.

Páginas de inicio de sesión falsas

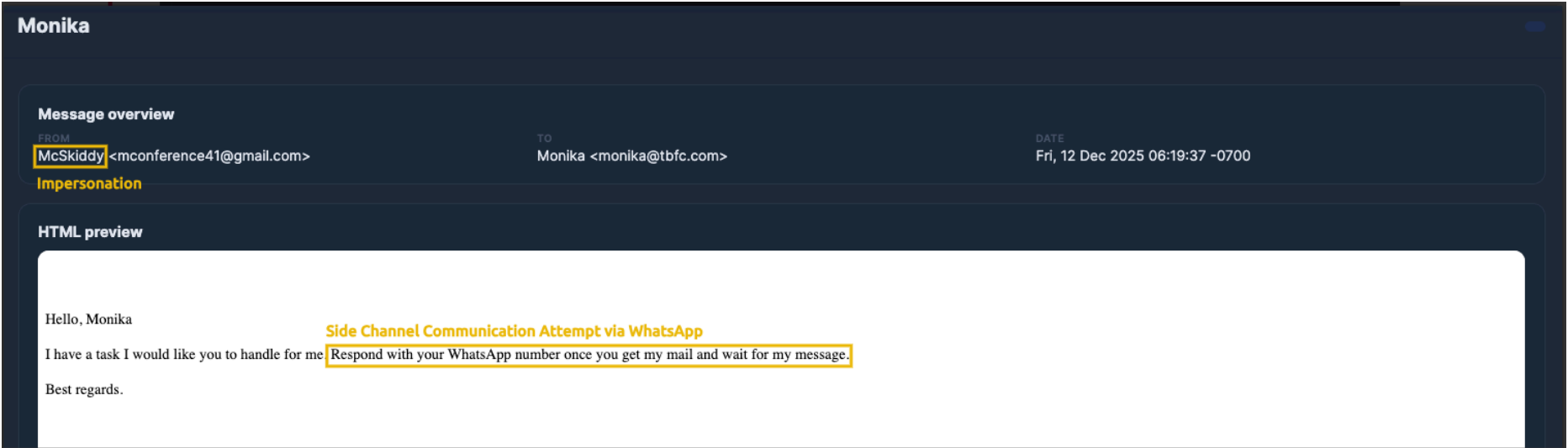
Como vimos, las credenciales son el principal objetivo de los atacantes hoy en día, y las páginas de inicio de sesión falsas son su truco favorito para lograrlo. Es simple e imita las páginas de inicio de sesión de diversas aplicaciones habituales con las que los usuarios interactúan en su día a día. En la mayoría de los casos, crean plataformas de correo electrónico falsas y portales de inicio de sesión como Microsoft Office 365 y Google.



Arriba se muestra un ejemplo de una página de inicio de sesión falsa de Microsoft. Podemos observar el dominio falso microsoftonline.login444123.com/signin en la parte superior.

Comunicaciones de canal lateral

La comunicación de canal lateral ocurre cuando un atacante traslada la conversación del correo electrónico a otro canal, como SMS, WhatsApp/Telegram, una llamada telefónica o videollamada, un enlace de SMS o una plataforma de documentos compartidos, para continuar la ingeniería social en una plataforma fuera del control de la empresa.



¡Es hora de detectar el phishing y salvar el SOC-mas!

Tu misión: Clasifica los correos electrónicos, separa el spam del phishing e identifica tres señales claras (por ejemplo: suplantación de identidad, ingeniería social) para cada correo electrónico de phishing que marques.
Obtendrás una bandera tras seleccionar las señales correctas para un correo electrónico de phishing. Reúne banderas para todos los correos de phishing para completar la sala y proteger el SOC-mas de TBFC.

¡Sigue investigando los correos electrónicos y consigue las banderas para cada correo enviado correctamente! Mantente alerta, verifica antes de actuar y que tus instintos sean más agudos que los trucos de los Eggsplot Bunnies. ¡Mucha suerte!

Answer the questions below

Classify the 1st email, what's the flag?

Invoice from Santa Claus (4103)

Message overview

FROM

"service@paypal.com" <service@paypal.com>

TO

"naeryn@tbfc.com" <naeryn@tbfc.com>

DATE

Fri, 12 Dec 2025 10:36:44 -0700

HTML preview

Here's your invoice

Santa Claus sent you an invoice for \$699.89 USD

Invoice details

Amount requested

\$699.89 USD

Note from seller

Fraud Alert, Didn't make this easter egg order? Call PayPal immediately at +1 (800) XMAS-1225

Invoice number

4103

View and Pay Invoice

Attachments

No attachment found.

Headers

RECEIVED	from DM6PR07MB6956.namprd07.prod.outlook.com (2603:10b6:5:1eb::9) by MN2PR07MB8048.namprd07.prod.outlook.com with HTTPS; Fri, 12 Dec 2025 14:16:12 +0000
RECEIVED	from MW4PR03CA0341.namprd03.prod.outlook.com (2603:10b6:303:dc::16) by DM6PR07MB6956.namprd07.prod.outlook.com (2603:10b6:5:1eb::9) with Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7897.23; Fri, 12 Dec 2025 14:16:06 +0000
RECEIVED	from CO1PEPF000042AD.namprd03.prod.outlook.com (2603:10b6:303:dc:cafe::7a) by MW4PR03CA0341.outlook.office365.com (2603:10b6:303:dc::16) with Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7897.25 via Frontend Transport; Fri, 12 Dec 2025 14:16:06 +0000
AUTHENTICATION-RESULTS	spf=fail (sender IP is 209.222.82.143) smtp.mailfrom=Danielle378.onmicrosoft.com; dkim=fail (body hash did not verify) header.d=paypal.com;dmarc=fail action=oreject header.from=paypal.com;compauth=none reason=451
RECEIVED-SPF	Fail (protection.outlook.com: domain of bbunny378.onmicrosoft.com does not designate 209.222.82.143 as permitted sender) receiver=protection.outlook.com; client-ip=209.222.82.143; helo=outbound-ip122b.ess.barracuda.com;
DKIM-SIGNATURE	v=1; a=rsa-sha256; d=paypal.com; s=pp-dkim1; c=relaxed/relaxed; q=dns/txt; i=@paypal.com; t=1724681744; h=From:From:Subject:Date:To:MIME-Version:Content-Type; bh=QAx3vqqhWgVnrGUcDi7Oo1ydwDuOHllzBFxro/aNaEQ=: b=z6tydmN+RWp+f9nRGjcmB5wGt!TrUrBxKvd2eyXajuy4+AIMMAC54z9toRraR8G4 htGJQflq+eoi04a1wJBfyg0qS0O2VtSwBLmSNWliS+whFzRowrvAQaA+MPRzOevX XI/ujTc/MEGTliEWmCYemlQd4z23HmzzvX05UzSA08Khxe0dCLARKDiO9sN3yaZA

Links detected

- https://www.paypalobjects.com/digitalassets/c/system-triggered-email/n/layout/fonts/PayPalOpen/PayPalOpen-Regular.otf
- https://www.paypalobjects.com/digitalassets/c/system-triggered-email/n/layout/fonts/PayPalOpen/PayPalOpen-Regular.woff2
- https://www.paypalobjects.com/digitalassets/c/system-triggered-email/n/layout/fonts/PayPalOpen/PayPalOpen-Regular.woff
- https://www.paypalobjects.com/digitalassets/c/system-triggered-email/n/layout/fonts/PayPalOpen/PayPalOpen-Medium.otf
- https://www.paypalobjects.com/digitalassets/c/system-triggered-email/n/layout/fonts/PayPalOpen/PayPalOpen-Medium.woff2
- https://www.paypalobjects.com/digitalassets/c/system-triggered-email/n/layout/fonts/PayPalOpen/PayPalOpen-Medium.woff
- https://www.paypalobjects.com/digitalassets/c/system-triggered-email/n/layout/fonts/PayPalOpen/PayPalOpen-Bold.otf
- https://www.paypalobjects.com/digitalassets/c/system-triggered-email/n/layout/fonts/PayPalOpen/PayPalOpen-Bold.woff2
- https://www.paypalobjects.com/digitalassets/c/system-triggered-email/n/layout/fonts/PayPalOpen/PayPalOpen-Bold.woff
- https://www.paypalobjects.com/digitalassets/c/system-triggered-email/n/layout/images/paypal-rebranding/pp-logo-in-circle-2x.png
- https://www.paypal.com/invoice/payerView/details/INV2-DQKT-267K-H7JK-2PE7?locale.x=en_US&v=1&utm_source=unp&utm_medium=email&utm_campaign=RT000238&utm_unptid=ad876434-63b5-11ef-9e2f-ac1f6bdab585&ppid=RT000238&cnac=US&rsta=en_US%28en-US%29&cust=&unptid=ad876434-63b5-11ef-9e2f-ac1f6bdab585&calc=b97c6970b5319&unp_tpcid=invoice-buyer-notification&page=main%3Aemail%3ART000238&pgrp=main%3Aemail&e=cl&mchn=em&s=ci&mail=sys&appVersion=1.275.0&tenant_name=&xt=145585%2C134644%2C104038&link_ref=details_inv2-dqkt-267k-h7jk-2pe7
- https://www.paypal.com/invoice/payerView/details/INV2-DQKT-267K-H7JK-2PE7?locale.x=en_US&action=report-spam&v=1&utm_source=unp&utm_medium=email&utm_campaign=RT000238&utm_unptid=ad876434-63b5-11ef-9e2f-ac1f6bdab585&ppid=RT000238&cnac=US&rsta=en_US%28en-US%29&cust=&unptid=ad876434-63b5-11ef-9e2f-ac1f6bdab585&calc=b97c6970b5319&unp_tpcid=invoice-buyer-notification&page=main%3Aemail%3ART000238&pgrp=main%3Aemail&e=cl&mchn=em&s=ci&mail=sys&appVersion=1.275.0&tenant_name=&xt=145585%2C134644%2C104038&link_ref=details_inv2-dqkt-267k-h7jk-2pe7
- https://www.paypalobjects.com/digitalassets/system-triggered-email/warning.png
- https://www.paypal.com/tc/webapps/mpp/security/comFri-scams?v=1&utm_source=unp&utm_medium=email&utm_campaign=RT000238&utm_unptid=ad876434-63b5-11ef-9e2f-ac1f6bdab585&ppid=RT000238&cnac=US&rsta=en_US%28en-US%29&cust=&unptid=ad876434-63b5-11ef-9e2f-ac1f6bdab585&calc=b97c6970b5319&unp_tpcid=invoice-buyer-notification&page=main%3Aemail%3ART000238&pgrp=main%3Aemail&e=cl&mchn=em&s=ci&mail=sys&appVersion=1.275.0&tenant_name=&xt=145585%2C134644%2C104038&link_ref=security_comFri-scams
- https://www.paypalobjects.com/digitalassets/c/system-triggered-email/n/layout/images/paypal-rebranding/footer-logo-with-crop-2x.png
- https://www.paypal.com/us/smarthelp/home?v=1&utm_source=unp&utm_medium=email&utm_campaign=RT000238&utm_unptid=ad876434-63b5-11ef-9e2f-ac1f6bdab585&ppid=RT000238&cnac=US&rsta=en_US%28en-US%29&cust=&unptid=ad876434-63b5-11ef-9e2f-ac1f6bdab585&calc=b97c6970b5319&unp_tpcid=invoice-buyer-notification&page=main%3Aemail%3ART000238&pgrp=main%3Aemail&e=cl&mchn=em&s=ci&mail=sys&appVersion=1.275.0&tenant_name=&xt=145585%2C134644%2C104038&link_ref=smarthelp_home
- https://www.paypal.com/us/webapps/mpp/paypal-safety-and-security?v=1&utm_source=unp&utm_medium=email&utm_campaign=RT000238&utm_unptid=ad876434-63b5-11ef-9e2f-ac1f6bdab585&ppid=RT000238&cnac=US&rsta=en_US%28en-US%29&cust=&unptid=ad876434-63b5-11ef-9e2f-ac1f6bdab585&calc=b97c6970b5319&unp_tpcid=invoice-buyer-notification&page=main%3Aemail%3ART000238&pgrp=main%3Aemail&e=cl&mchn=em&s=ci&mail=sys&appVersion=1.275.0&tenant_name=&xt=145585%2C134644%2C104038&link_ref=mpn-safety-and-security

Classification

☐ Spam ☒ Phishing

Select at least three phishing signals:

- ☐ Impersonation
- ☐ Typosquatting/Punycodes
- ☐ External Sender Domain
- ☒ Spoofing
- ☐ Social Engineering Text
- ☒ Sense of Urgency
- ☒ Fake Invoice
- ☐ Malicious Attachment
- ☐ Fake Login Page
- ☐ Side Channel Communication Attempt

Submit

Correct! Flag: THM{yougotnumber1-keep-it-going}

Correct: Spoofing Sense of Urgency Fake Invoice
Incorrect: None

Classify the 2nd email. What's the flag?

Respuesta: THM{number2-was-not-tha-thard!}

New Audio Message from McSkidy

Message overview

FROM	TO	DATE
McSkidy Missed Call Notifier <calls@tbfc.com>	tarron@tbfc.com	Sun, 12 Oct 2025 18:12:34 +0000

HTML preview

Hi Tarron

You have a new Voice Message from McSkidy:

ID: 405-405-0405
Duration: 88 seconds
Date: October 12, 2025
Organization: TBFC

Attachments

Play-Now.mp3-29a-otpqw-warq-29.html

attachment; filename="Play-Now.mp3-29a-otpqw-warq-29.html"
Type: application/octet-stream
Size: 1.7 KB

Headers

RECEIVED	from DU2PR08MB10188.eurprd08.prod.outlook.com (2603:10a6:10:46f::12) by AM9PR08MB6004.eurprd08.prod.outlook.com with HTTPS; Fri, 12 Dec 2025 11:55:03 +0000
RECEIVED	from AS9PR04CA0039.eurprd04.prod.outlook.com (2603:10a6:20b:46a::33) by DU2PR08MB10188.eurprd08.prod.outlook.com (2603:10a6:10:46f::12) with Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7897.13; Fri, 12 Dec 2025 11:53:15 +0000
RECEIVED	from AMS0EPF0000014F.eurprd05.prod.outlook.com (2603:10a6:20b:46a:cafe::22) by AS9PR04CA0039.outlook.office365.com (2603:10a6:20b:46a::33) with Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7875.21 via Frontend Transport; Fri, 12 Dec 2025 11:53:12 +0000
AUTHENTICATION-RESULTS	spf=fail (sender IP is 173.243.133.97) smtp.mailfrom=tbfc.com; dkim=fail (signature did not verify) header.d=tbfc.com; dmarc=fail action=none header.from=tbfc.com; compauth=none reason=405
RECEIVED-SPF	Fail (protection.outlook.com: domain of transitioning tbfc.com discourages use of 173.243.133.97 as permitted sender)
RECEIVED	from gw3097.weakmail.com (173.243.133.97) by AMS0EPF0000014F.mail.protection.outlook.com (10.167.16.251) with Microsoft SMTP Server (version=TLS1_3, cipher=TLS_AES_256_GCM_SHA384) via Frontend Transport; Fri, 12 Dec 2025 11:53:12 +0000
AUTHENTICATION-	qw3097.weakmail.com; spf=permerror (weakmail.com: 143.55.232.2 is neither permitted nor denied by domain of bounce+35b744.72834a-calls.com@tbfc.com) smtp.mailfrom=bounce+35b744.7

Links detected

No direct links were found in the selected email.

Classification

☐ Spam ☒ Phishing

Select at least three phishing signals:

☒ Impersonation

☐ Typosquatting/Punycodes

☐ External Sender Domain

☒ Spoofing

☐ Social Engineering Text

☐ Sense of Urgency

☐ Fake Invoice

☒ Malicious Attachment

☐ Fake Login Page

☐ Side Channel Communication Attempt

Submit

Correct! Flag: THM{nmumber2-was-not-tha-thard!}

Correct:

Impersonation

Spoofing

Malicious Attachment

Incorrect:

None

Classify the 3rd email. What's the flag?

Respuesta: THM{Impersonation-is-areal-thing-keepIt}

URGENT: McSkidy VPN access for incident response

Message overview

FROM	TO	DATE
McSkidy <mcskiddy202512@gmail.com>	TBFC Blue Team <blueteam@tbfc.com>	Sun, 14 Dec 2025 04:05:09 +0000

HTML preview

Team,

McSkidy here — I'm currently unreachable by phone. We have an ongoing incident and need the Blue Team to get remote access now to investigate. Please create a new VPN access for me immediately. Send the access to my personal email address **mcskiddy202512@gmail.com**

Name	McSkidy
Team	Blue Team
Reason	Emergency incident response

This is urgent — please action immediately.

— McSkidy

Attachments

No attachment found.

Headers

RECEIVED	from AM2PEPF0001C70C.eurprd05.prod.outlook.com (2603:10a6:20b:45a:cafe::35) by AS9PR06CA0298.outlook.office365.com (2603:10a6:20b:45a::6) with Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7849.22 via Frontend Transport; Fri, 14 Dec 2025 04:05:10 +0000
RECEIVED	from mail-wm1-f67.google.com (209.85.128.67) by AM2PEPF0001C70C.mail.protection.outlook.com (10.167.16.200) with Microsoft SMTP Server (version=TLS1_3, cipher=TLS_AES_256_GCM_SHA384) id 15.20.7849.8 via Frontend Transport; Fri, 14 Dec 2025 04:05:10 +0000
RECEIVED	from 341605307468 named unknown by gmailapi.google.com with HTTPREST; Fri, 14 Dec 2025 04:05:09 +0000
AUTHENTICATION-RESULTS	spf=pass (sender IP is 209.85.128.67) smtp.mailfrom=gmail.com; dkim=pass (signature was verified) header.d=gmail.com;dmarc=pass header.from=gmail.com;compauth=pass reason=111
RECEIVED-SPF	Pass (protection.outlook.com: domain of gmail.com designates 209.85.128.67 as permitted sender) receiver=protection.outlook.com; client-ip=209.85.128.67; helo=mail-wm1-f67.google.com; pr=C
DKIM-SIGNATURE	v=1; a=rsa-sha256; c=relaxed/relaxed; d=gmail.com; s=google; t=1723608310; x=1724213110; darn=gmail.com; h=to:subject:message-id:date:mime-version:from:user-agent:in-reply-to:references:from:to:cc:subject:date:message-id:reply-to; bh=JPDbPId0FhMLkx73Fa1XuTA6b3dKaoyqn+GhtJVVee8=; b=kJMBe6v7T9QfTTit+Mgzzz6yhBWoj5CD5kzCtfRBMD7ashn/0Z6/IPJK9Z/oIUsdZc lxbB/maStZuBudhionCY3YhpHaZWLPiXBPxTT5dEJwirMhaGJO5FQfeWecRKrjHsrd+p

Links detected

No direct links were found in the selected email.

Classification

☐ Spam ☒ Phishing

Select at least three phishing signals:

☒ Impersonation

☐ Typosquatting/Punycodes

☐ External Sender Domain

☐ Spoofing

☒ Social Engineering Text

☒ Sense of Urgency

☐ Fake Invoice

☐ Malicious Attachment

☐ Fake Login Page

☐ Side Channel Communication Attempt

Submit

Correct! Flag: THM(Impersonation-is-areal-thing-keepIt)

Correct:

Incorrect:

Classify the 4th email. What's the flag?

Respuesta: THM{Get-back-SOC-mas!!}

TBFC HR Department shared "Annual Salary Raise Approval.pdf" with you

Message overview

FROM

TBFC HR Department <no-reply@dropbox.com>

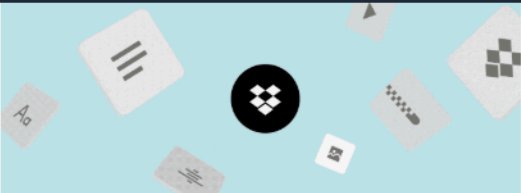
TO

Neymar Junior <neymar.junior@tbfc.com>

DATE

Fri, 12 Dec 2025 21:00:16 +0000

HTML preview



TBFC HR Department (hr.tbfc@outlook.com) invited you to view the file "Annual Salary Raise Approval.pdf" on Dropbox.

"Hi there, You have a pending document to be signed regarding you recent Salary Raise Approval. You can copy and paste the URL below if you do not have a DropBox account:

https://www.dropbox.com/scl/fi/xzruzfwqa4w770zxvq00i/annual-salary-raise-approval.pdf?blablabla Thank you, TBFC HR Department"

Open file

Attachments

No attachment found.

Headers

	cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.7633.15 via Frontend Transport; Fri, 12 Dec 2025 21:00:18 +0000
AUTHENTICATION-RESULTS	spf=pass (sender IP is 54.240.60.157) smtp.mailfrom=email.dropbox.com; dkim=pass (signature was verified) header.d=dropbox.com;dkim=pass (signature was verified) header.d=amazonses.com;dmarc=pass action=none header.from=dropbox.com;compauth=pass reason=100
RECEIVED-SPF	Pass (protection.outlook.com: domain of email.dropbox.com designates 54.240.60.157 as permitted sender) receiver=protection.outlook.com; client-ip=54.240.60.157; helo=a60-157.smtp-out.us-west-2.amazonses.com; pr=C
DKIM-SIGNATURE	v=1; a=rsa-sha256; q=dns/txt; c=relaxed/simple; s=b55ck4kgrdgjxhl3qlcrbmzyg4d26eak; d=dropbox.com; t=1717016416; h=Content-Type:MIME-Version:From:To:CC:Subject:Date:Message-ID:Reply-To; bh=43982798473YTHIUERHGC99842374HWECRUHEW9R8EWRUCW=; b=dsf s7s7f98dsfds7fs98dfusd8fuds8fud8sfcsjd=
DKIM-SIGNATURE	v=1; a=rsa-sha256; q=dns/txt; c=relaxed/simple; s=7v7vs6w47njt4pimodk5mmttbegzsi6n; d=amazonses.com; t=1717016416; h=Content-Type:MIME-Version:From:To:CC:Subject:Date:Message-ID:Reply-To:Feedback-ID; bh=fsdjknfskjdfnsdjkfns32424234jk23b4kh=; b=fihsdufys86r4yt386rh3r8hf3789qhf8fh38hf63823uhei2hjwehdfjwfhwywgfuyg2863b=
CONTENT-TYPE	multipart/mixed; boundary="-----sinikael-?=_1-17170166112790.013752983326257961"
MIME-VERSION	1.0

Links detected

- <http://www.w3.org/TR/REC-html40/loose.dtd>
- <http://www.w3.org/1999/xhtml>
- <https://www.dropbox.com/static/fonts/proximanova/proxima-nova-regular.otf>
- <https://www.dropbox.com/static/fonts/atlasgrotesk/AtlasGrotesk-Regular.otf>
- <https://www.dropbox.com/static/fonts/sharpgrotesk/SharpGroteskDBMedium22.woff>
- <https://aka.ms/LearnAboutSenderIdentification>
- <https://assets.dropbox.com/email/en/receiving-experience/folder.gif>
- <https://www.
- <https://www.dropbox.com/l/scl/AACsXe1xmrtqdCP5FFny-TmiHK765YmljLdd>
- <https://assets.dropbox.com/email/en/receiving-experience/Open@3x.png>
- <http://schema.org>
- <https://apps.apple.com/us/app/dropbox-cloud-photo-storage/id327630330>
- <https://assets.dropbox.com/email/en/receiving-experience/Apple@3x.png>
- <https://play.google.com/store/apps/details?id=com.dropbox.android>
- <https://assets.dropbox.com/email/en/receiving-experience/Android@3x.png>
- https://www.dropbox.com/l/AACe5cKHnMcy0cgJYjm5ph112TKs_M/report_abuse
- <https://www.dropbox.com/l/AADZZLWLrhI5L-fultNxt2K3HkZlozz5AqQ>

Classification

☐ Spam ☒ Phishing

Select at least three phishing signals:

- ☒ Impersonation
- ☐ Typosquatting/Punycodes
- ☒ External Sender Domain
- ☐ Spoofing
- ☒ Social Engineering Text
- ☐ Sense of Urgency
- ☐ Fake Invoice
- ☐ Malicious Attachment
- ☐ Fake Login Page
- ☐ Side Channel Communication Attempt

Submit

Correct! Flag: THM(Get-back-SOC-mas!!)

- Correct:

Impersonation

External Sender Domain

Social Engineering Text
- Incorrect:

None

Classify the 5th email. What's the flag?

Respuesta: THM{It-was-just-a-sp4m!!}

Improve your event logistics this SOC-mas season

Message overview

FROM

Lara <lara@candycane-co.wv>

TO

TBFC Events <events@tbfc.com>

DATE

Sun, 14 Dec 2025 04:05:09 +0000

HTML preview

Dear TBFC Team,

I hope this message finds you well during this busy SOC-mas season.

We understand how challenging it can be to manage large-scale festive events — endless volunteer coordination, costume distribution, and late-night preparation. Our **CandyCane Co. Logistics Platform** was designed to simplify those processes and reduce workload for event managers across Wareville.

- Automated scheduling for staff and volunteers
- Centralized supply tracking for costumes and decorations
- Real-time updates to minimize delivery errors
- Energy-efficient systems that cut operational costs

I'd love to learn how TBFC currently handles event logistics and see if our solution could support your preparations for SOC-mas. Even small improvements could bring huge time savings to your team.

Looking forward to hearing from you,

Warm regards,
Lara
Event Solutions Advisor
CandyCane Co.

© 2025 CandyCane Co. | 45 Frostbite Avenue, Wareville

Attachments

No attachment found.

Headers

	cipher=TLS_AES_256_GCM_SHA384) id 15.20.7849.8 via Frontend Transport; Wed, 14 Aug 2024 04:05:10 +0000
RECEIVED	by mail-wm1-f67.google.com with SMTP id 5b1f17b1804b1-427fc97a88cso47415525e9.0 for <shafkath_nur@tbfc.com>; Tue, 13 Aug 2024 21:05:10 -0700 (PDT)
RECEIVED	from 341605307468 named unknown by gmailapi.google.com with HTTPREST; Wed, 14 Aug 2024 04:05:09 +0000
RECEIVED	from 83.72.202.35.bc.googleusercontent.com (83.72.202.35.bc.googleusercontent.com [35.202.72.83]) by api.nylas.com (Nylas) with HTTPREST id cnk1mfnwhrxc7kuiwnzjgdzti-0; Wed, 14 Aug 2024 04:03:50 +0000 (UTC)
AUTHENTICATION-RESULTS	spf=pass (sender IP is 209.85.128.67) smtp.mailfrom=tewsworks.net; dkim=pass (signature was verified) header.d=tewsworks.net;dmARC=none action=none header.from=tewsworks.net;compauth=pass reason=111
RECEIVED-SPF	Pass (protection.outlook.com: domain of tewsworks.net designates 209.85.128.67 as permitted sender) receiver=protection.outlook.com; client-ip=209.85.128.67; helo=mail-wm1-f67.google.com; pr=C
DKIM-SIGNATURE	v=1; a=rsa-sha256; c=relaxed/relaxed; d=tewsworks.net; s=google; t=1723608310; x=1724213110; darn=tbfc.com; h=to:subject:message-id:date:mime-version:from:user-agent:in-reply-to:references:from:to:cc:subject:date:message-id:reply-to; bh=JPDbPId0FhMLkx73Fa1XuTA6b3dKaoyqn+GhtJVVeE8=; b=kJMBe6v7T9QfTtit+Mgzzz6yhBWoj5CD5kzCtfRBMD7ashn/0Z6/IPJK9Z/olUsdZc lxbB/maStZuBudhionCY3YhpHaZWLPiXBpTT5dEJwirMhaGJO5FQfeWecRKrjHsrd+p

Links detected

No direct links were found in the selected email.

Classification

☒ Spam

☐ Phishing

Submit

Correct! Flag: THM{It-was-just-a-sp4m!!}

Classify the 6th email. What's the flag?

Respuesta: THM{number6-is-the-last-one!-DX!}

TBFC-IT shared "Christmas Laptop Upgrade Agreement" with you

Message overview

FROM

TBFC-IT <tbfc-it@tbfc.com>

TO

Savoy <savoys@tbfc.com>

DATE

Fri, 12 Dec 2025 17:29:34 +0000

HTML preview

TBFC-IT shared a file with you

Here's the document that TBFC-IT shared with you.

Christmas Laptop Upgrade Agreement

This link only works for the direct recipients of this message.

Open

Microsoft

[Privacy Statement](#)

Attachments

No attachment found.

Headers

ACCEPT-LANGUAGE	en-US
CONTENT-LANGUAGE	en-US
RECEIVED-SPF	Pass (protection.outlook.com: domain of tbfc.com designates 148.163.129.48 as permitted sender) receiver=protection.outlook.com; client-ip=148.163.129.48; helo=dispatch1-us1.ppe-hosted.cor
AUTHENTICATION-RESULTS	spf=pass (sender IP is 148.163.129.48) smtp.mailfrom=tbfc.com; dkim=pass (signature was verified) header.d=NETORGFT5333146.onmicrosoft.com;dmarc=none action=none header.from=tbfc.c reason=109
DKIM-SIGNATURE	v=1; a=rsa-sha256; c=relaxed/relaxed; d=NETORGFT5333146.onmicrosoft.com; s=selector1-NETORGFT5333146-onmicrosoft-com; h=From:Date:Subject:Message-ID:Content-Type:MIME-Version:X-MS-Exchange-Organization; bh=VpUaEZsM02oIFjPbW9CqXrwP+llK++M1QazeU9FUD7c=; b=Ebcwp+HuNVOehTJhb55dRU4XvieFAmSt+8jC7a2yTtUpDrWtjljuqVMir1PfVt11Q0S87xX0ndPbVoMI+3SQZGJEJDhR+RUepuEGGG9R/hAWdcpVKK9ooLtgqLoEO5swHYj4zpi3vTbgzZnsu2xUQYOv5,
AUTHENTICATION-RESULTS-ORIGINAL	dkim=none (message not signed) header.d=none;dmarc=none action=none header.from=tbfc.com;

Links detected

- <https://microsoftoline.co>
- <https://www.microsoft.com/en-us/privacy/privacystatement>
- <http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd>
- <http://www.w3.org/1999/xhtml>
- <https://static2.sharepointonline.com/files/fabric/assets/fonts/segoeui-westeuropean/segoeui-light.woff2>
- <https://static2.sharepointonline.com/files/fabric/assets/fonts/segoeui-westeuropean/segoeui-light.woff>
- <https://static2.sharepointonline.com/files/fabric/assets/fonts/segoeui-westeuropean/segoeui-light.ttf>
- <https://static2.sharepointonline.com/files/fabric/assets/fonts/segoeui-westeuropean/segoeui-semilight.woff2>
- <https://static2.sharepointonline.com/files/fabric/assets/fonts/segoeui-westeuropean/segoeui-semilight.woff>
- <https://static2.sharepointonline.com/files/fabric/assets/fonts/segoeui-westeuropean/segoeui-semilight.ttf>
- <https://static2.sharepointonline.com/files/fabric/assets/fonts/segoeui-westeuropean/segoeui-regular.woff2>
- <https://static2.sharepointonline.com/files/fabric/assets/fonts/segoeui-westeuropean/segoeui-regular.woff>
- <https://static2.sharepointonline.com/files/fabric/assets/fonts/segoeui-westeuropean/segoeui-regular.ttf>
- <https://static2.sharepointonline.com/files/fabric/assets/fonts/segoeui-westeuropean/segoeui-semibold.woff2>
- <https://static2.sharepointonline.com/files/fabric/assets/fonts/segoeui-westeuropean/segoeui-semibold.woff>
- <https://static2.sharepointonline.com/files/fabric/assets/fonts/segoeui-westeuropean/segoeui-semibold.ttf>
- <http://microsoftoline.co>
- <https://aka.ms/privacy>
- <https://southcentralusr-notifyp.svc.ms:443/api/v2/tracking/method/View?mi=nQ8xfUXZlkuNvJuouYwfOg>

Classification

- ☐ Spam
- ☒ Phishing

Select at least three phishing signals:

☒ Impersonation

☒ Typosquatting/Punycodes

☐ External Sender Domain

☐ Spoofing

☒ Social Engineering Text

☐ Sense of Urgency

☐ Fake Invoice

☐ Malicious Attachment

☐ Fake Login Page

☐ Side Channel Communication Attempt

Submit

Correct! Flag: THM{number6-is-the-last-one!-DX!}

Correct:

Impersonation

Typosquatting/Punycodes

Social Engineering Text

Incorrect:

None

If you enjoyed today's room, you can explore the [Phishing Analysis Tools](#) room in detail!

Check

Wareville Email Threat Inspector

Automatic classification has been disabled. Manual mode is currently the only available option.

Available Emails

Invoice from Santa Claus (4103)

From: "service@paypal.com" <service@paypal.com>
To: "naeryn@tbfc.com" <naeryn@tbfc.com>
Fri, 12 Dec 2025 10:36:44 -0700

New Audio Message from McSkidy

From: McSkidy Missed Call Notifier <calls@tbfc.com>
To: tarron@tbfc.com
Sun, 12 Oct 2025 18:12:34 +0000

URGENT: McSkidy VPN access for incident response

From: McSkidy <mcskiddy202512@gmail.com>
To: TBFC Blue Team <blueteam@tbfc.com>
Sun, 14 Dec 2025 04:05:09 +0000

TBFC HR Department shared "Annual Salary Raise Approval.pdf" with you

From: TBFC HR Department <no-reply@dropbox.com>
To: Neymar Junior <neymar.junior@tbfc.com>
Fri, 12 Dec 2025 21:00:16 +0000

Improve your event logistics this SOC-mas season

From: Lara <lara@candycane-co.wv>
To: TBFC Events <events@tbfc.com>
Sun, 14 Dec 2025 04:05:09 +0000

TBFC-IT shared "Christmas Laptop Upgrade Agreement" with you

From: TBFC-IT <tbfc-it@tbfc.com>

Select an email to inspect

Awaiting selection

Choose an email from the list to load its content, headers, and link analysis.